VULNERABILITY MANAGEMENT PROCESS

SOP-017 | Standard Operating Procedure | Issued under POL-017

Document ID: SOP-017
Version: 1.0 — DRAFT
Parent Policy: POL-017 — Vulnerability Management Policy
Classification: Internal Use
Owner: Information Security
Co-Owner: CIO
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Vulnerability Management Process
Document ID	SOP-017
Version	1.0 — DRAFT
Parent Policy	POL-017 — Vulnerability Management Policy
Related Documents	POL-005 (System Classification), POL-006 (CSV), POL-007 (Change Management), POL-009 (PAM), POL-010 (IS Risk), POL-012 (Incident Response), POL-014 (Audit Trail), POL-015 (ITSM), SOP-006 (Validation), SOP-007 (Change Management), SOP-009 (PAM), SOP-010 (IS Risk Assessment), SOP-012 (Incident Response), SOP-014 (Audit Trail Review), SOP-015 (ITSM), EXC-001, RACI-001
Owner	Information Security Manager
Co-Owner	CIO
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]

IMPORTANT: The vulnerability register is the single source of truth for all known open vulnerabilities. A vulnerability that is not in the register does not officially exist — which means it has no SLA, no owner, and no remediation plan. Every vulnerability identified through any channel must be logged in the register on the day it is identified. Information Security is accountable for register completeness.

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This SOP defines the operational procedures for the [Company Name] vulnerability management programme — from scan execution through triage, remediation tracking, GxP patching decisions, penetration testing commissioning, and the annual programme review. It operationalises POL-017 by establishing the specific steps, decision points, escalation paths, and documentation requirements for each stage of the vulnerability lifecycle.

2. Scope

This SOP applies to all vulnerability management activities for [Company Name] in-scope systems: all tier-assigned systems, all GxP systems, all SOX ITGC systems, network infrastructure, and end-user devices. It covers vulnerabilities identified through automated scanning, penetration testing, threat intelligence, vendor advisories, security incident investigation, and internal discovery.

3. Roles and Responsibilities

Role	Responsibility
Information Security Manager	Vulnerability programme lead. Owns vulnerability register. Oversees scanning programme. Triages all identified vulnerabilities. Assigns severity and SLA. Tracks remediation. Escalates SLA breaches. Commissions and oversees penetration tests. Produces programme reporting.
CISO	Vulnerability programme owner (POL-017). Receives Critical vulnerability notifications. Approves Critical and GxP exception requests. Reviews penetration test reports. Approves formal risk acceptance decisions. Board-level vulnerability reporting.
Data Custodian (IT)	Technical remediation execution — patch deployment, configuration remediation, mitigating control implementation. Confirms remediation completion to Information Security. Manages scan credentials in PAM. Coordinates scan scheduling with System Owners.
Compliance / QA	Joint owner of GxP patching decisions (Section 6). Reviews VIA for GxP system patches. Confirms validated state impact assessment. Issues GxP Restart Authorisation post-patch where validated state is affected. Notified of all vulnerability findings on GxP systems regardless of severity.
System Owners	Notified of Critical and High vulnerabilities on their systems. Accountable for remediation within their system boundary. Authorise mitigating controls that affect system functionality. Participate in GxP patching

Role	Responsibility
	decisions.
CIO	Notified of Critical vulnerabilities on Tier 1 systems. Co-approves GxP patching exceptions with CISO. Reviews monthly Tier 1/GxP vulnerability report.

4. Vulnerability Register

The vulnerability register is the operational backbone of the vulnerability management programme. It is a live document — updated on the day a vulnerability is identified and tracked until confirmed remediated or formally accepted.

4.1 Mandatory Register Fields

Field	Description
Vulnerability ID	Sequential identifier: VUL-YYYY-NNN
Date identified	Date vulnerability was logged — SLA clock start
Source	How identified: Scan / Penetration Test / Threat Intelligence / Vendor Advisory / Internal Discovery / Incident Investigation
CVE reference	CVE number where assigned. 'No CVE' where not yet assigned or not applicable.
CVSS base score	CVSS v3.1 base score from NVD or vendor. 'Pending' if not yet published.
Contextual severity	Information Security-assigned severity after applying contextual factors per POL-017 Section 2: Critical / High / Medium / Low / Informational. Must differ from CVSS base score where contextual factors apply — with documented rationale.
Affected systems	System ID(s) from System Register. All affected systems listed — a single CVE may affect multiple systems with different contextual severities.
GxP flag	Yes / No — whether any affected system has a GxP flag
SOX ITGC flag	Yes / No
Remediation SLA date	Calculated from contextual severity and date identified per POL-017 Section 2
Status	Open / Mitigated (control in place) / Remediated (patch/fix applied) / Exception Approved / Risk Accepted / Closed
Remediation owner	Named individual in Data Custodian (IT) or application team responsible for remediation
Mitigating control	Where status is Mitigated: description of the control in place and the date applied
Patch / fix reference	Where status is Remediated: SOP-007 change record reference and patch version applied
Exception reference	Where status is Exception Approved or Risk Accepted: EXC-001 exception ID and expiry date
Remediation confirmed	Date Information Security confirmed the vulnerability is resolved. Method of confirmation (re-scan, manual verification).

Field	Description
IS Risk Register ref	SOP-010 risk register entry reference — mandatory for all Critical and High vulnerabilities, and for all exceptions
Notes	Any additional context — vendor advisory reference, threat intelligence link, GxP VIA reference, penetration test finding reference

4.2 Register Hygiene

Information Security Manager reviews the vulnerability register at minimum weekly. The following conditions are treated as register hygiene failures and escalated to CISO:

- Any Critical or High vulnerability with no remediation owner assigned
- Any Critical vulnerability with no status update for more than 24 hours
- Any vulnerability past its SLA date with status still 'Open' and no exception approved
- Any exception whose expiry date has passed without renewal or closure
- Any 'Mitigated' vulnerability where the mitigating control has not been confirmed as active within the last 30 days

5. Scanning Operations

Step 01	**Scan Scheduling and Pre-Authorisation** Information Security maintains a scan calendar, published in the SOP-007 change calendar for visibility: — Weekly scans for Tier 1, Tier 2, and GxP systems: scheduled for low-traffic periods (typically weekend nights or early morning weekdays) to minimise performance impact — GxP systems: scan activity pre-authorised as a Standard Change in SOP-007 change calendar. The scan pre-authorisation specifies: scan window, scan type, scanning system IP address. This prevents scan-generated audit trail entries from triggering DIRA investigations or SOP-014 SIEM alerts. — Scan credentials: stored in PAM platform per SOP-009. Credentials are service accounts with least-privilege read access for scanning. Credentials rotated quarterly per PAM rotation schedule. — New system onboarding: Information Security adds new systems to the scan scope within 5 business days of system going live. System Owner informed of scan schedule.	Responsible **Information Security**
Step 02	**Scan Execution and Monitoring** Automated scans run per the schedule without manual intervention. Information Security monitors scan completion: — Scan completion confirmed: every scheduled scan must generate a completion report. A scan with no completion report by the end of the scan window is treated as a scan failure. — Scan failure response: Information Security investigates within 4 hours of expected completion. Common causes:	Responsible **Information Security**

	scanning system network connectivity, credential expiry, target system availability. Scan is re-run once the cause is resolved. — Scan coverage confirmation: Information Security confirms quarterly that all in-scope systems are actively being scanned and are reachable by the scanner. Systems not reachable by the scanner are an IS Risk Register finding. — Unscheduled scans: any scan outside the published schedule requires Information Security Manager approval and is logged as a change in ITSM.	
Step 03	**Scan Results Triage** On receipt of scan results, Information Security triages all findings within one business day for Critical and High, within three business days for Medium and Low: 1. Deduplicate: confirm whether the finding is new or a previously known open vulnerability. If previously known: update the existing register entry (new affected system, new scan confirmation). Do not create duplicate register entries for the same CVE on the same system. 2. Confirm the finding: validate that the finding is a true positive. Automated scanners generate false positives — particularly for version-based detection where a backported patch means a reported version is not actually vulnerable. Information Security confirms true positives before logging. 3. Apply contextual severity: assign contextual severity per POL-017 Section 2. Document the rationale where contextual severity differs from the CVSS base score. 4. Log in vulnerability register: all confirmed true positives logged on the day of triage. SLA clock starts at the date of the scan that identified the vulnerability — not the date of triage. 5. Notify: Critical → System Owner and CIO notified within 4 hours of triage. High → System Owner notified within 24 hours. GxP findings (any severity) → Compliance / QA notified on the day of triage.	Responsible **Information Security**

6. GxP Patching Decision Process

Every vulnerability finding on a GxP system requires a patching decision that explicitly addresses the validated state. The following workflow is mandatory for all GxP vulnerabilities — it cannot be abbreviated or bypassed.

Step 01	**GxP Vulnerability Notification** On identification of any vulnerability (any severity) on a GxP system: 1. Information Security logs in vulnerability register with GxP flag set to Yes 2. Compliance / QA notified on the day of identification — not after the SLA is calculated, not after triage is complete 3. Joint assessment initiated: Information Security (security risk) and Compliance / QA (validated state risk) assess the vulnerability together Compliance / QA receives: CVE reference, CVSS base score, Information Security contextual severity assessment, description of the vulnerability, affected GxP system(s), and any threat intelligence indicating active exploitation.	Responsible **Information Security / Compliance QA**

Step 02	**Validation Impact Pre-Assessment** Compliance / QA and Information Security jointly conduct a rapid Validation Impact Pre-Assessment (VIPA) — a lighter-weight step than a full VIA, designed to establish the patching pathway before a detailed VIA is commissioned: VIPA questions: 1. Does the vulnerability affect a component that is within the validated boundary of the GxP system? 2. Is a patch available from the vendor? 3. Has the vendor issued a statement on whether the patch affects validated functionality? 4. What is the likely patching pathway: (a) patch with no validated state impact, (b) patch with validated state impact requiring full VIA and partial re-validation, or (c) no patch available — mitigating control required? 5. What is the estimated time to complete a full VIA and implement the patch? VIPA output: one of the three pathways in POL-017 Section 5.2. The VIPA is documented in the vulnerability register and referenced in the subsequent VIA if a full VIA is required. VIPA timeline: completed within 24 hours for Critical vulnerabilities, within 3 business days for High, within 7 business days for Medium.	Responsible **Information Security / Compliance QA**
Step 03	**Pathway A — Patch with No Validated State Impact** Where VIPA confirms the patch does not affect validated functionality: 1. Information Security raises an Emergency Change (Critical) or Normal Change (High/Medium) in SOP-007 2. Change record includes: CVE reference, VIPA reference, Compliance / QA concurrence statement 3. Patch deployed per SOP-007 change process 4. Post-patch: Information Security conducts a re-scan to confirm vulnerability is remediated 5. Post-patch: Compliance / QA conducts a post-change audit trail review (per SOP-014) — confirms no unexpected changes to GxP system behaviour 6. Vulnerability register updated: status → Remediated. VMF entry: patch applied, VIPA reference, Compliance / QA concurrence, audit trail review confirmation. 7. Validated state: maintained throughout. No GxP restart authorisation required.	Responsible **Data Custodian IT / Compliance QA**
Step 04	**Pathway B — Patch with Validated State Impact** Where VIPA determines the patch may affect the validated state: Phase 1 — Mitigating control (within SLA window): 1. Information Security implements a mitigating control to close the exploitation path — network isolation, WAF rule, access restriction, or disabling the vulnerable component 2. Mitigating control confirmed effective: Information Security confirms the exploitation path is blocked 3. Vulnerability register updated: status → Mitigated. Mitigating control description and date recorded. 4. SLA compliance confirmed: the mitigating control within the SLA window satisfies the SLA for the purpose of regulatory and policy compliance Phase 2 — Full VIA and patch (within 30 days of mitigating control): 1. Full Validation Impact Assessment (VIA) commissioned: scope of re-validation required per SOP-006 VIA process 2. Patch scheduled as a Normal Change in SOP-007, with VIA reference and Compliance / QA co-approval 3. Patch deployed in test/staging environment first. Regression testing against GxP functionality. 4. Patch deployed to production per SOP-007 change window 5. OQ re-execution (partial or full, per VIA determination) confirms validated state is intact post-patch 6. Compliance / QA Director issues GxP Restart Authorisation if the system	Responsible **Information Security / Data Custodian IT / Compliance QA / Validation Lead**

	was taken offline during patching 7. VMF updated: VIA reference, patch change record, OQ re-execution result, GxP Restart Authorisation reference 8. Vulnerability register updated: status → Remediated.	
Step 05	**Pathway C — No Patch Available** Where no vendor patch is available: 1. Mitigating control implemented within the SLA window — same as Pathway B Phase 1 2. EXC-001 exception requested before SLA expiry: CISO approval for Critical/High. Exception specifies: vulnerability, affected GxP system, mitigating control in place, monitoring plan, expected patch availability date (if known) 3. IS Risk Register entry raised via SOP-010: open vulnerability risk with named owner (CISO), mitigating control noted, and review cadence (weekly for Critical, monthly for High) 4. Weekly re-assessment for Critical: Information Security monitors vendor advisory channel for patch availability. On patch release: Pathway A or B initiated immediately. 5. At 90 days without patch: formal risk acceptance process initiated per POL-017 Section 7. Board notification required for Critical vulnerabilities at this stage. 6. Vulnerability register updated: status → Exception Approved or Risk Accepted with exception/risk acceptance reference.	Responsible **Information Security / CISO / Compliance QA**

7. Standard (Non-GxP) Remediation Workflow

For non-GxP systems, the remediation workflow is streamlined. The validated state dimension is absent, but the change management obligation (SOP-007) and the SLA tracking obligation remain.

Step 01	**Critical and High Remediation** On identification of a Critical or High vulnerability on a non-GxP system: 1. Information Security notifies System Owner and CIO (Critical) or System Owner (High) within the notification timelines in Section 5.3 2. Remediation owner assigned (Data Custodian IT or application team member) within 4 hours for Critical, 24 hours for High 3. Remediation plan agreed: patch vs. mitigating control vs. architecture change. Patch is preferred where available. 4. For Critical: Emergency Change in SOP-007 if patch can be applied within 72 hours. For High: Normal Change in SOP-007. 5. Patch or mitigating control applied within SLA 6. Remediation confirmed: Information Security conducts a targeted re-scan of the affected system within 48 hours of remediation to confirm the vulnerability is resolved. Re-scan result documented in vulnerability register. 7. Vulnerability register updated: status → Remediated. SOP-007 change record reference logged.	Responsible **Information Security / Data Custodian IT / System Owner**
Step 02	**Medium and Low Remediation** Medium and Low vulnerabilities follow the same process but with less urgency: — Remediation owner assigned within 5 business days —	Responsible **Information Security / Data**

	Remediation scheduled in the standard patch cycle (Section 8) where the patch is included in the next scheduled maintenance window — Standard Change in SOP-007 for routine patches — Remediation confirmed at next scheduled scan after the patch is applied — a targeted re-scan is not required for Medium/Low unless Information Security judges the risk warrants it — Vulnerability register updated on confirmation	**Custodian IT**

Step 03	**SLA Breach Response** When a vulnerability's SLA date is reached without remediation or an approved exception: 1. Information Security Manager identifies the breach in the weekly register review 2. Escalation per POL-017 Section 3: Critical → CISO and CIO notified immediately; High → CISO notified; Medium → Information Security Manager notified (owns the escalation) 3. IS Risk Register entry raised via SOP-010: the open vulnerability is now a formal IS risk 4. Exception requested immediately (after the fact): CISO approves. Post-SLA exceptions are noted as such in EXC-001 — a distinction from pre-SLA exceptions where the decision was made in time 5. Root cause of the SLA breach documented: was it resource, technical obstacle, or process failure? Root cause drives whether a problem record (SOP-015) is needed 6. Vulnerability register updated: SLA breach date and escalation reference recorded	Responsible **Information Security Manager / CISO**

8. Patch Cycle Management

Beyond emergency and targeted patching, [Company Name] operates a structured patch cycle for routine vulnerability remediation. The patch cycle is not a substitute for SLA-driven emergency patching — it is the mechanism for remediating Medium and Low vulnerabilities efficiently, in batches, with controlled change management.

Patch Cycle	Systems Covered	Frequency	Process
Monthly patch cycle	All Tier 1, Tier 2, and GxP systems — OS and middleware patches	Monthly, within the first 14 calendar days of each month	Data Custodian (IT) prepares patch list from vulnerability register and vendor advisories. Information Security reviews for any Critical/High items that should have been patched earlier (should not appear in monthly cycle — they have their own SLA). Patches tested in staging environment (Tier 1 and GxP mandatory, Tier 2 recommended). Change record raised in SOP-007. Patch deployed per change window. GxP patches include VIPA per Section 6.
Quarterly application patch cycle	All in-scope applications — application-level patches not	Quarterly	Application owners and Data Custodian (IT) review pending application vulnerabilities. Patches tested. Normal Change in SOP-007. GxP applications: VIA per Section 6.

Patch Cycle	Systems Covered	Frequency	Process
	addressed by monthly OS cycle		
Emergency patch (out-of-cycle)	Any system — Critical or actively exploited High vulnerability	As required — within SLA	Emergency Change in SOP-007. CISO authorises. Patch tested in staging where time permits (minimum 2-hour staging test for Critical patches on Tier 1 systems). If staging is not possible: rollback plan confirmed before production deployment. Post-patch re-scan within 24 hours.
End-of-life (EOL) component tracking	All systems — OS, middleware, and application components approaching or past EOL	Reviewed quarterly as part of vulnerability programme review	Data Custodian (IT) maintains EOL register: component, EOL date, replacement plan, and current vulnerability exposure. Components past EOL with no patch availability are immediately escalated to Information Security as permanent vulnerability risks — POL-017 Section 7 exception process applies.

9. Penetration Testing Process

Step 01	**Annual Test Planning** By [date — typically Q4 of the preceding year], CISO and Information Security Manager agree the annual penetration testing plan: — Scope: Tier 1 systems and GxP systems (internal test); all internet-facing systems and APIs (external test) — Test type for each scope: black-box, grey-box, or white-box. Rationale documented. — Provider selection: CREST-certified or equivalent. Provider rotation: same provider not used for external test in consecutive years. — Scheduling: coordinated with GxP production calendar to avoid testing during regulatory inspection windows or critical processing periods. Tier 1 test windows confirmed with CIO. — Pre-test notification: System Owners of all in-scope systems notified of test dates and scope at least 2 weeks in advance.	Responsible **CISO / Information Security Manager**
Step 02	**Pre-Engagement Setup** Before testing begins: 1. Statement of work agreed and signed: scope, methodology, rules of engagement, deliverables, timeline 2. Rules of engagement confirmed in writing: no production data access beyond proof-of-concept, no service disruption, exploitation depth limits, out-of-scope systems explicitly listed 3. GxP pre-authorisation: penetration test scope covering GxP systems entered as a Standard Change in SOP-007 change calendar. The change record identifies: test window, testing provider IP addresses, test scope. This pre-authorisation prevents test-generated audit trail entries from triggering DIRA investigations. 4. Emergency stop procedure confirmed: a named Information Security	Responsible **Information Security / Data Custodian IT**

	contact who can halt the test immediately if unexpected impact is observed. Provider has this contact detail before testing begins. 5. Scan credentials (where grey-box or white-box): created as temporary accounts per SOP-008, scoped to the minimum access needed for the test. Accounts expire automatically at the end of the test window.	
Step 03	**During Testing** Information Security monitors SIEM alerts during the penetration test window: — SOP-014 Category 5 alerts (exploitation attempts) will be generated by penetration test activity — these are expected and are noted as 'known test activity' in SIEM triage during the test window — Any unexpected system behaviour, service impact, or data access beyond what was agreed in the rules of engagement: Information Security contacts the provider emergency stop contact immediately — Daily check-in with the provider during multi-day tests: confirm no unexpected findings requiring immediate escalation (e.g., discovery of evidence of a pre-existing breach) If the penetration test discovers evidence of an actual, pre-existing compromise (not the tester's own activity): testing pauses. CISO notified immediately. SOP-012 activated. Testing resumes only after CISO confirms the SOP-012 investigation has addressed the pre-existing compromise.	Responsible **Information Security**
Step 04	**Findings Management** On receipt of the penetration test report: 1. Information Security Manager reviews the full report within 5 business days of receipt 2. Each finding is logged in the vulnerability register as a new vulnerability entry (source: Penetration Test). VUL-YYYY-NNN identifier assigned. SLA clock starts from the date of report receipt. 3. CISO briefed on the report within 5 business days: overview of Critical and High findings, any systemic weaknesses identified, comparison with prior year findings if available 4. System Owners of systems with Critical or High findings notified within 24 hours of CISO briefing 5. GxP findings: Compliance / QA notified of all findings affecting GxP systems. VIPA initiated per Section 6 Step 2 for any finding on a GxP system regardless of severity. 6. Remediation follows standard workflow (Section 7) and GxP patching workflow (Section 6) as applicable 7. Re-test: Critical and High findings are re-tested by the provider after remediation. Re-test results appended to the original report. Re-test confirmed in vulnerability register.	Responsible **Information Security Manager / CISO / System Owners**

10. Threat Intelligence Integration

Step 01	**CISA KEV Monitoring** Information Security reviews the CISA Known Exploited Vulnerabilities catalogue at minimum weekly — automated alerting configured where available: 1. New KEV entries assessed against the system inventory:	Responsible **Information Security**

	does [Company Name] have systems running the affected component? 2. If affected: immediate escalation to Critical severity regardless of CVSS base score. Contextual severity in vulnerability register updated to Critical with KEV reference noted. 3. If already in the vulnerability register as a lower severity: register entry updated, SLA recalculated from the current date as if it were a new Critical identification. System Owner and CIO notified within 4 hours. 4. If not previously identified: new register entry created. SLA clock starts from the KEV publication date (not the date [Company Name] discovered the KEV entry).	
Step 02	**Vendor Advisory Processing** Information Security reviews vendor security advisories within 24 hours of receipt: 1. Advisory assessed against the system inventory: which [Company Name] systems run the affected product/version? 2. Affected systems identified: vulnerability logged in the register. Severity assigned per POL-017 Section 2. SLA clock starts at the advisory receipt date. 3. GxP vendor advisories: Compliance / QA notified immediately for any advisory affecting a GxP system component — even before full severity assessment is complete. 4. Advisory with no affected systems: documented as 'Not Applicable' in the ITSM advisory log. Rationale confirms why no [Company Name] system is affected. 5. Advisory acknowledged, no patch yet available: register entry created with status Mitigating Control Pending. Information Security assesses whether any interim mitigating controls are available.	Responsible **Information Security**

11. Exception Process

All vulnerability remediation exceptions are governed by EXC-001 and the constraints in POL-017 Section 7. The following steps apply to all exception requests under this SOP.

Step 01	**Exception Request — Before SLA Expiry** Exception requests must be submitted before the SLA expiry date — not after. A post-SLA exception is an SLA breach with a retrospective exception, which is a different and more serious finding. Exception request must include: — Vulnerability ID and severity — Why remediation cannot be completed within the SLA: specific, documented reason (not 'we've been busy') — Mitigating controls in place: description, evidence of effectiveness — Proposed remediation timeline with milestones — Residual risk assessment: what is the risk with the mitigating control in place? — IS Risk Register entry reference (created before or alongside the exception request) — For GxP systems: Compliance / QA co-signature on the exception request	Responsible **Information Security / System Owner / Compliance QA (GxP)**
Step 02	**Exception Approval** Approval authority per POL-017 Section 7. On approval: 1. EXC-001	Responsible **CISO /**

	exception record created with all required fields and the expiry date 2. Vulnerability register updated: status → Exception Approved. EXC-001 reference and expiry date recorded. 3. Information Security calendar entry created for 7 days before exception expiry — advance review to confirm whether remediation has been completed or a renewal is required 4. Monthly confirmation that the mitigating control remains active — documented in vulnerability register	**Information Security Manager**
Step 03	**Exception Renewal or Escalation to Risk Acceptance** At exception expiry: Option A — Remediation complete: vulnerability register updated to Remediated. Exception closed in EXC-001. Option B — Renewal needed: same approval process as initial exception. Renewal is not automatic — the reason for the continued delay must be documented and the mitigating control re-confirmed effective. No exception may be renewed more than twice without CISO escalation to formal risk acceptance. Option C — Formal risk acceptance: where the vulnerability cannot be remediated within a reasonable timeframe (e.g., vendor EOL, GxP system requiring full replacement), formal risk acceptance is initiated per POL-017 Section 7. This requires CISO, CIO, and Board approval. IS Risk Register entry elevated. Board reporting per Section 9.	Responsible **CISO / Information Security Manager**

12. Annual Vulnerability Programme Review

The annual review is a programme-level governance assessment — not a review of individual vulnerabilities. It assesses whether the programme is functioning effectively and producing the outcomes required by POL-017.

Review Item	Assessment Question	Owner
SLA compliance	What is the 12-month SLA compliance rate by severity? How many SLA breaches occurred and what were the root causes?	Information Security Manager
Scan coverage	Are all in-scope systems being scanned at the required frequency? Any gaps identified in the year?	Information Security
Penetration test outcomes	Were both annual tests completed? What were the Critical/High finding counts? Year-on-year trend. Were all findings remediated and re-tested?	CISO / Information Security Manager
GxP programme health	How many GxP vulnerabilities were identified? How many	Compliance QA / Information Security

Review Item	Assessment Question	Owner
	required Pathway B or C? Any open GxP vulnerabilities with active exceptions? Any GxP validated state impacts?	
Exception volume and age	How many exceptions were granted? How many were renewed? How many escalated to risk acceptance? Any exceptions open more than 6 months?	Information Security Manager / CISO
EOL component inventory	Current EOL component list. Any components past EOL with no replacement plan? Funded replacement roadmap status.	Data Custodian IT / CIO
Threat intelligence integration	Was the CISA KEV monitored weekly without gaps? How many KEV entries affected [Company Name] systems? Average time from KEV publication to register entry?	Information Security
Tooling and capability	Is the scanning toolset adequate? Any scan types missing (DAST, container, CSPM)? Tooling upgrade requirements?	Information Security Manager / CIO
IS Risk Register alignment	Are all open Critical and High vulnerabilities represented in the IS Risk Register? Any discrepancies?	Information Security / SOP-010

Annual review report produced by Information Security Manager, approved by CISO. Findings raised as change requests (SOP-007) and IS Risk Register entries (SOP-010). Report presented to ISSG. Retained as a controlled record per POL-002.

13. Related Documents

Document ID	Title	Relationship
POL-017	Vulnerability Management Policy	Parent policy — this SOP operationalises POL-017
POL-005	System Classification Policy	System tier determines scan frequency, SLA priority, and penetration test scope
POL-006	CSV Policy	GxP patching requires VIA per SOP-006. VIPA is

Document ID	Title	Relationship
		the lightweight pre-assessment step. Penetration test pre-authorisation as SOP-007 change prevents DIRA false positives.
POL-007	Change Management Policy	All patches are SOP-007 changes. Critical/zero-day: Emergency Change. GxP patches: Normal Change with VIA. Scan and penetration test activity pre-authorised as Standard Changes.
POL-009	PAM Policy	Scan credentials and penetration test accounts managed in PAM per SOP-009. Credentials expire automatically post-test.
POL-010	IS Risk Policy	All open Critical/High vulnerabilities, SLA breaches, accepted risks, and programme gaps are IS Risk Register entries via SOP-010.
POL-012	Incident Response Policy	Active exploitation of a known vulnerability activates SOP-012. Penetration test discovery of a pre-existing compromise pauses testing and activates SOP-012.
POL-014	Audit Trail Policy	Scan and penetration test activity pre-authorised to prevent SIEM Category 5 false alerts. Exploitation attempts detected in SIEM are Category 5 alerts per SOP-014.
SOP-006	Computer System Validation Process	VIA for GxP patches. OQ re-execution post-patch where VIA determines validated state impact.
SOP-007	Change Management Process	All patches and remediation changes flow through SOP-007.
SOP-010	IS Risk Assessment Process	Vulnerability programme feeds IS Risk Register. All Critical/High open vulnerabilities have IS Risk Register entries.
SOP-012	Security Incident Response Process	Active exploitation triggers SOP-012. KEV-listed vulnerability on [Company Name] systems triggers parallel SOP-012 assessment.
SOP-014	Audit Trail Review Process	SIEM Category 5 alerts for exploitation attempts. Scan pre-authorisation prevents false DIRA triggers.
EXC-001	Exception Management Policy and Register	All remediation exceptions governed by EXC-001 subject to POL-017 Section 7 constraints.
RACI-001	Roles, Responsibilities and Authorities	Accountability for vulnerability management governance.

— End of Document —

SOP-017 v1.0 DRAFT | [Company Name] | INTERNAL USE